Cybersecurity Capstone

Project Title: From Vulnerability To Compliance: Securing Legacy Systems At Apex Healthcare Solutions.

Student Name: Joseph Olayinka Olaoluwa

Group Number: 18

Submission Date:

1. Background

Apex Healthcare Solutions is a medium-sized health care technology company that provides digital patient record services to clinics and hospitals. The company recently hired a cybersecurity

consulting team (your team) to perform a security review of two legacy systems that were discovered running inside their environment:

- Kioptrix
- Metasploitable2

The internal security team conducted vulnerability assessments and identified multiple weaknesses across both systems.

Management is concerned that these vulnerabilities could lead to:

- Unauthorized access
- Data breaches
- Service disruption
- Regulatory compliance violations
- Damage to company reputation Rather than focusing one xploitation , management wants a report that explains:

    1. What vulnerabilities exist.
    2. Why they are dangerous.
    3. What business risks they create.
    4. What security controls and policies should be implemented to reduce those risks.

2. Project Objective

Using findings from Kioptrix and Metasploitable2 labs completed during training:

- Identify discovered vulnerabilities.
- Explain the security impact of each vulnerability.
- Assess business risk.
- Recommend security controls.
- Recommend organizational policies.
- Present findings in a professional report

3. Task1: Vulnerability Identification (Kioptrix)

Create subsections for 3 Kioptrix and 3 Metasploitable 2 vulnerabilities.

Table:
Vulnerability Name | Affected Service | Description | Potential Attacker Goal

VULNERABILITY 1

REQUIREMENT	ANSWER
Vulnerability Name	Outdated Apache HTTP Server
Affected Service	Apache HTTP Server (Ports 80 & 443)
Brief Description	The web server is using Apache HTTP Server version 1.3.20, an outdated release that no longer receives security updates. Because of its age, this version may contain publicly known vulnerabilities that attackers could exploit to gain unauthorized access or disrupt services.
Potential Attacker Goal	Exploit known vulnerabilities in the outdated web server to gain unauthorized access, execute malicious code, or steal sensitive information.

VULNERABILITY 2

REQUIREMENT	ANSWER
Vulnerability Name	Outdated OpenSSH Service
Affected Service	OpenSSH (Port 22)
Brief Description	The system is running OpenSSH version 2.9p2, an outdated SSH service. Older versions may contain security weaknesses that could allow attackers to compromise remote access if they are exploited.
Potential Attacker Goal	Gain unauthorized remote access to the server or compromise administrator accounts.

VULNERABILITY 3

REQUIREMENT	ANSWER
Vulnerability Name	Exposed Samba Service
Brief Description	The Samba file-sharing service is accessible over the network. If it is outdated or misconfigured, attackers may exploit known weaknesses to access shared resources or gather information about the system.
Potential Attacker Goal	Access shared files, gather information about the network, or exploit Samba vulnerabilities to gain unauthorized access.

Vulnerability Identification (Metasploitable 2)

VULNERABILITY 1

REQUIREMENT	ANSWER
Vulnerability Name	UnrealIRCd Backdoor
Affected Service	IRC (Port 6667)
Brief Description	The UnrealIRCd service is running a version that contains a known backdoor. An attacker could exploit this service to execute unauthorized commands on the server.
Potential Attacker Goal	Execute malicious commands and gain control of the system.

VULNERABILITY 2

REQUIREMENT	ANSWER
Vulnerability Name	VSFTPD 2.3.4 Backdoor
Affected Service	FTP (Port 21)
Brief Description	The system is running VSFTPD version 2.3.4. This version is known for a backdoor vulnerability and is intentionally included in Metasploitable 2 for security training.
Potential Attacker Goal	Gain unauthorized access to the server or execute malicious commands by exploiting the vulnerable FTP service.

VULNERABILITY 3

REQUIREMENT	ANSWER
Vulnerability Name	Exposed Telnet Service
Affected Service	Telnet (Port 23)

Brief Description	Telnet provides remote access without encrypting traffic. Usernames and passwords can be transmitted in plain text, making them vulnerable to interception on the network.
Potential Attacker Goal	Capture login credentials or gain unauthorized remote access to the server.

4. Task 2: Risk Assessment

Kioptrix

Vulnerability	Likelihood	Impact	Risk Rating	Explanation
Outdated Apache HTTP Server	High	High	High	Since the Apache server is outdated, it presents a significant security risk. Attackers may take advantage of publicly known vulnerabilities to compromise the web server, access sensitive information, or interrupt normal business operations.
Outdated OpenSSH	Medium	High	High	Exploitation may require specific conditions or known weaknesses, but successful exploitation could allow unauthorized remote access.

Exposed Samba Service	High	High	High	Samba has had several wellknown vulnerabilities. If exploited, it could expose files or provide unauthorized access to the system.

Metasploiatble 2

Vulnerability	Likelihood	Impact	Risk Rating	Explanation
UnrealIRCd Backdoor	High	High	High	The backdoored IRC service allows attackers to execute unauthorized commands, creating a high risk to the system.
VSFTPD 2.3.4 Backdoor	High	High	High	This version contains a known backdoor, making exploitation straightforward in a training environment and potentially leading to full system compromise.

Exposed Telnet Service	High	High	High	Telnet transmits credentials in plain text. Attackers on the network could intercept login information and gain unauthorized access.

5. Task3: Security Control Recommendations

Vulnerability	Recommended Control	How the Control Reduces Risk
Outdated Apache HTTP Server	Patch Management Process	Regularly updating Apache to a supported version fixes known security vulnerabilities and reduces the risk of attackers exploiting outdated software
Outdated OpenSSH	Update OpenSSH and Disable Legacy Protocols	Upgrading to the latest supported version removes known vulnerabilities and improves the security of remote access.
Exposed Samba Service	Restrict Access and Update Samba	Limit access to authorized users only, disable unnecessary shares, and keep Samba updated to reduce the risk of unauthorized access and exploitation.

UnrealIRCd Backdoor	Remove the Backdoored Version and Install a Secure Release	Installing a trusted, updated version eliminates the backdoor and prevents attackers from executing unauthorized commands.
VSFTPD 2.3.4 Backdoor	Upgrade or Replace the FTP Service	Replacing the vulnerable version with a secure, supported FTP server removes the known backdoor and prevents unauthorized access
Exposed Telnet Service	Disable Telnet and Use SSH Instead	SSH encrypts all communication, protecting usernames, passwords, and data from being intercepted on the network.

6. Task4: GRC Policy Recommendations

1. Access Control Policy

Purpose:
To ensure that only authorized users can access company systems, applications, and sensitive patient information.

Why Apex Healthcare Solutions needs it:
As a healthcare technology company, Apex stores sensitive patient records. Limiting system access helps protect confidential information and reduces the risk of unauthorized access.

Vulnerabilities it helps mitigate:

- Outdated OpenSSH
- Exposed Telnet Service
- Exposed Samba Service

2. Patch Management Policy

Purpose:
To ensure that all operating systems, applications, and network services are regularly updated with the latest security patches.

Why Apex Healthcare Solutions needs it:

Many of the identified vulnerabilities were caused by outdated software. A formal patch management process helps prevent attackers from exploiting known security flaws.

Vulnerabilities it helps mitigate:

- Outdated Apache HTTP Server
- Outdated OpenSSH
- VSFTPD 2.3.4 Backdoor
- UnrealIRCd Backdoor

3. Vulnerability Management Policy

Purpose:
To establish a process for regularly identifying, assessing, prioritizing, and remediating security vulnerabilities.

Why Apex Healthcare Solutions needs it:
Routine vulnerability assessments allow the organization to detect weaknesses before attackers can exploit them and reduce overall cybersecurity risk.

Vulnerabilities it helps mitigate:

- All identified vulnerabilities in Kioptrix and Metasploitable 2.

4. Acceptable Use Policy

Purpose:
To define how employees should use company systems, networks, internet access, and organizational resources responsibly.

Why Apex Healthcare Solutions needs it:
Employees play an important role in maintaining security. Clear usage rules reduce the chances of accidental misuse, insecure practices, or policy violations that could expose systems to attack.

Vulnerabilities it helps mitigate:

- Exposed Telnet Service

- Exposed Samba Service
- Unauthorized access risks

7. Task5: Executive Summary

Executive Summary

This assessment examined two legacy systems, Kioptrix and Metasploitable 2, to understand the security risks they pose to Apex Healthcare Solutions. The review focused on identifying vulnerabilities, evaluating their potential business impact, and recommending practical technical controls and governance policies to strengthen the organization's overall security.

Key Findings

The assessment identified six major vulnerabilities across both systems, including outdated Apache and OpenSSH services, exposed Samba and Telnet services, the VSFTPD 2.3.4 backdoor, and the UnrealIRCd backdoor. These vulnerabilities increase the likelihood of unauthorized access, remote system compromise, data breaches, and service disruption.

Highest-Risk Vulnerabilities

The highest-risk vulnerabilities include the **VSFTPD 2.3.4 backdoor**, **UnrealIRCd backdoor**, **outdated Apache HTTP Server**, and the **exposed Telnet service**. These weaknesses are well documented and could allow attackers to gain unauthorized access, execute malicious commands, or intercept sensitive information if exploited.

Recommended Security Controls

To reduce these risks, the organization should implement a structured patch management process, upgrade or replace outdated software, disable insecure services such as Telnet, replace vulnerable applications with secure versions, restrict unnecessary network access, and regularly perform vulnerability assessments to identify and remediate security weaknesses.

Recommended Policies

To strengthen security governance, Apex Healthcare Solutions should implement and enforce an **Access Control Policy**, **Patch Management Policy**, **Vulnerability Management Policy**, and **Acceptable Use Policy**. These policies will help ensure secure system administration, timely software updates, continuous vulnerability management, and responsible use of organizational resources.

Overall Security Posture

The current security posture of the legacy systems is **high risk** due to multiple outdated services and known vulnerabilities. While these systems were intentionally vulnerable for assessment purposes, the findings demonstrate the importance of proactive security management. By implementing the recommended technical controls and governance policies, Apex Healthcare Solutions can significantly reduce cyber risk, improve regulatory compliance, and better protect sensitive patient information and critical business operations.